

Re-audit result

I checked:

- the complete **SIH26106 problem statement**
- the actual PEC **SIH 2026 Guidelines.pdf**
- PEC's internal SIH email
- the current `/root/sih-mailtrace` code, fixtures, UI, tests, PDFs, PPTX files, and screenshots
- the live API behavior

Bottom line: MailTrace is a working, honest prototype/demo. It is **not yet the complete end-state platform described in the official problem statement**, and the current deck is **not submission-ready** because it still contains placeholders.

1. Complete official problem statement

Problem Statement ID: SIH26106

Title: *Development of an AI-Powered Platform for Email Threat Detection and GeoLocation of Fraudulent Sources*

Organization: AICTE Cyber Security Cell

Theme: Blockchain & Cybersecurity

Category: Software

Official portal: [SIH 2026 Problem Statements](#)

Accessible PS text mirror: [SIH26106](#)

What problem are they describing?

Fraudulent emails are becoming harder to detect because attackers use:

- AI-generated language
- impersonation and display-name spoofing
- lookalike domains
- concealed redirects
- forged or manipulated headers
- relay chains
- compromised infrastructure
- cloud servers, proxies, VPNs, TOR, and open relays

Normal spam filters usually focus on the email body or sender address. They do not perform a complete forensic investigation of the email's content, headers, routing path, origin infrastructure, and relationship to previous attacks.

What solution are they asking for?

They want an **end-to-end AI-powered email investigation platform** that can analyze a suspicious email and help an investigator determine:

1. Is the message legitimate, suspicious, spoofed, phishing, BEC, or otherwise fraudulent?
 2. Which technical headers and routing information are suspicious?
 3. What is the earliest reliable sending infrastructure?
 4. Where is that infrastructure located?
 5. Is it connected to VPNs, TOR, proxies, cloud providers, botnets, or open relays?
 6. Has the same infrastructure or campaign appeared before?
 7. Is the account compromised, the domain spoofed, the infrastructure anonymized, or the actor directly malicious?
 8. Can the evidence be preserved and reported in a legally useful way?
-

2. Every major requirement in the official PS

A. Fraudulent email detection engine

The platform should use NLP/ML to examine:

- subject-line urgency
- suspicious language
- impersonation
- payment or account-change requests
- credential harvesting
- business email compromise
- phishing indicators
- attachments and malicious links

It should classify email into categories such as:

- legitimate
- suspicious
- impersonated
- phishing
- fraud-related

It should also identify BEC patterns such as:

- urgent money transfers
- changed bank details
- fake executive requests
- requests for confidential information
- unusual replies or sender identities

B. Header and protocol analysis

It must inspect technical fields such as:

- Return-Path
- Received
- Message-ID
- Reply-To
- DKIM
- SPF
- DMARC

It should detect:

- inconsistencies between From, Reply-To, and Return-Path
- forged authentication results
- suspicious routing
- manipulated relay chains
- abnormal header ordering
- infrastructure that does not match the claimed sender

It should also validate whether the sender's infrastructure is genuinely authorized.

C. Origin traceability

The platform should:

- extract the originating IP address
- identify the earliest reliable sending node
- estimate country, region, city, ISP, and hosting provider
- identify proxies or anonymization
- correlate infrastructure with:
 - VPNs
 - TOR
 - open relays
 - botnets
 - cloud providers
 - perform domain intelligence using:
 - WHOIS
 - DNS
 - MX records
 - registrar information
 - hosting fingerprints
 - domain age and related data

D. Identity and campaign correlation

The platform should correlate a suspicious email with:

- threat-intelligence sources
- blacklists
- previous incidents
- repeated domains
- repeated IP addresses
- aliases
- reply chains
- linked infrastructure
- related fraud campaigns

It should build a graph connecting:

- sender domains
- IP addresses
- aliases
- reply addresses
- infrastructure
- campaigns

The system should produce an investigative assessment with confidence or uncertainty and identify whether the source looks like:

- a compromised account
- a spoofed domain
- anonymized infrastructure
- a direct malicious actor

E. Alerting, dashboard, and reports

The expected platform includes:

- real-time or near-real-time alerts
- alerts before a user interacts with the email
- an analyst dashboard
- fraud-risk scoring
- infrastructure/origin confidence
- visual trace maps
- relationship graphs
- structured forensic reports
- evidence suitable for institutional, legal, incident-response, or law-enforcement use
- searchable case management
- campaign grouping
- historical case comparison

F. Privacy and compliance

The platform should include:

- controlled handling of personal data and email metadata
- organizational privacy-policy support
- logging
- evidence preservation
- chain-of-custody support
- configurable retention periods
- masking or redaction of sensitive communication data

Expected result

The final system should help organizations:

- detect fraudulent emails early
 - investigate suspicious sources
 - trace infrastructure
 - correlate repeated attacks
 - preserve evidence
 - reduce financial loss
 - improve incident response
 - support law-enforcement investigation
-

3. What MailTrace already has

Verified working

The current project at `/root/sih-mailtrace` has:

- local `.eml` upload
- eight crafted email fixtures
- sender and reply-to extraction
- selected authentication-header display
- Received-chain parsing
- basic originating-IP detection
- basic risk scoring
- explainable risk reasons
- offline IP/location context
- a hop map
- a campaign graph
- SQLite case storage

- case listing
- PDF report generation
- SHA-256 evidence hash
- local-only operation
- clean UI screenshots
- six-slide PPTX and PDF deck

Live API verification passed:

- health endpoint: 200
- sample count: 8
- sample analysis: successful
- case storage: successful
- graph generation: successful
- PDF generation: successful
- invalid sample: correctly returned 404
- empty upload: correctly returned 400

Tests passed:

5 passed

The repository is also clean:

```
## main...origin/main
```

The local database was cleaned after testing, so the next demo can start from an empty case list.

4. Requirement-by-requirement gap analysis

Email detection

Current: Rule-based keyword and header heuristics.

Status: Partial.

What is missing:

- actual NLP model
- actual trained ML classifier
- calibrated confidence
- proper subject/body language analysis
- robust impersonation detection
- attachment analysis
- malicious-link analysis
- URL obfuscation detection
- HTML email analysis beyond the current limited parser

There are no local .pk1, .ipynb, TF-IDF, or teammate model files under /root. So we cannot claim that an ML model is integrated.

Header analysis

Current: Some headers are parsed and displayed.

Status: Partial.

The parser can access some useful fields, but the UI/report does not fully expose:

- Return-Path
- Message-ID
- complete raw authentication results
- detailed header anomalies
- cryptographic verification
- authenticated sender authorization

The system currently reads authentication-result strings. It does not independently verify SPF, DKIM, or DMARC against live DNS and cryptographic evidence.

Origin tracing

Current: Received hops and a small offline IP-context table.

Status: Demo-level partial.

What works:

- Received-hop extraction
- earliest-public-hop heuristic
- map visualization
- city/ISP context for known fixture IPs

What is missing:

- live GeoIP
- country/region/city confidence
- proxy/VPN/TOR detection
- botnet/open-relay correlation
- live DNS
- MX lookup
- WHOIS
- registrar intelligence
- hosting fingerprints
- live blacklist/threat-intelligence checks
- IPv6 handling
- robust relay validation

The current “location” is not a confirmed attacker location. It is infrastructure context and must be presented that way.

Identity and campaign correlation

Current: Local graph connecting analyzed cases through shared indicators.

Status: Partial.

The graph works for the demo, but it currently behaves more like a **case-similarity graph** than a full forensic entity graph.

Missing:

- external threat-intelligence correlation
- blacklist correlation
- domain/IP reputation
- alias identity linking
- reply-chain analysis
- campaign confidence
- probable sender identity assessment
- compromised-account classification
- anonymized-infrastructure classification
- direct-malicious-actor classification

The current risk score is **not the same thing as attribution confidence**.

Dashboard and alerting

Current: Local one-case dashboard with score, reasons, hop map, graph, and report export.

Status: Partial.

Missing:

- pre-interaction alerting
- inbox or mail-gateway integration
- quarantine/action workflow
- analyst search
- case filters
- campaign grouping UI
- alert history
- notification channels
- user/admin approval flow

The current app analyzes an email **after a user uploads it**. That is not yet real-time pre-delivery detection.

Forensic reports

Current: A PDF report with basic case information, score, reasons, origin/hops, campaign information, and hash.

Status: Partial.

Missing:

- full raw-header section
- attachment evidence
- URL/IOC section
- authentication verification details
- analyst identity
- event log
- immutable evidence history
- chain-of-custody records
- retention policy
- masking/redaction controls
- legal-grade evidence package

The hash is useful, but the original .eml evidence is not being preserved as a complete immutable evidence object with custody events.

Privacy and compliance

Current: Local-first design and no Gmail/inbox integration.

Status: Partial.

That is a good privacy decision for the prototype, but it is not a complete compliance implementation.

Missing:

- access control
 - masking
 - configurable retention
 - audit trail
 - immutable logs
 - evidence-custody workflow
 - policy configuration
 - deletion controls
-

5. What was specifically missed or left unfinished

Submission blockers

1. Team placeholders are still present

The current deck contains:

[ENTER PORTAL TEAM ID]

[ENTER REGISTERED TEAM NAME]

These appear in both:

- MailTrace_SIH26106_idea.pdf
- MailTrace_SIH26106_SUBMISSION.pdf

Both PDFs are six pages and byte-identical.

The editable PPTX files are also duplicates.

These must be replaced before any final upload.

2. The deck changed the official section headings

The deck currently uses:

- PROPOSED SOLUTION
- METHODOLOGY
- FEASIBILITY
- IMPACT
- RESEARCH
- REFERENCES

But it does not literally preserve headings such as:

- TECHNICAL APPROACH
- FEASIBILITY AND VIABILITY
- IMPACT AND BENEFITS
- RESEARCH AND REFERENCES

This is a compliance risk because the official template instructions say not to change the prescribed idea-detail pointers. The design is visually clean, but the literal official headings should be restored or visibly included.

3. The idea description overclaims confidence

docs/IDEA.md says the system reports the earliest reliable hop with confidence.

Current code does not calculate origin confidence. It provides:

- a heuristic earliest hop
- offline city/ISP context
- a disclaimer

The wording should be changed to something honest, such as:

"reports the earliest reliable observed hop with transparent infrastructure context and uncertainty."

Or we need to implement a real confidence model.

4. We need one canonical final file

There are multiple versions:

- MailTrace_SIH26106_idea.pdf
- MailTrace_SIH26106_SUBMISSION.pdf
- editable PPTX variants

They are currently duplicates, which creates avoidable confusion. After fixing the deck, export one final canonical PDF and use that consistently.

5. Portal/form status cannot be inferred from the repository

PEC's email said:

- internal selection is online
- date: **8 September 2026, 11:00 AM to 9 September 2026, 11:00 AM**
- shortlist: 45 teams
- waitlist: 5 teams
- leader form deadline: **31 August 2026, 11:59 PM**
- only team leaders submit the form

As of **1 September 2026 UTC**, that internal form deadline has passed.

I cannot honestly say whether our team submitted it because that information is not in the repository. We need confirm one of:

- form submission confirmation
- leader's sent/confirmation email
- PEC SPOC confirmation
- shortlisted-team announcement

If it was not submitted, contact the PEC SPOC immediately.

6. Official SIH submission rules that matter

From the SIH guideline document:

- team has **six students**
- members must be from the same institute
- at least one female member is required
- team name must be unique
- team name must not include PEC, institute name, or similar institution wording
- team leader handles submission
- only nominated/selected teams proceed to the national portal
- a team can select up to **two problem statements**
- a problem statement freezes at **500 ideas**
- the leader verifies team details, contacts, gender, and authorization information
- an authorization letter from the institute is required

- submission contains:
- idea title
- idea description
- prescribed idea-presentation PDF
- Word/PPT upload is not accepted as the final submission
- information cannot casually be changed after submission
- national SIH portal deadline: **20 September 2026, 11:59 PM**
- if selected for the grand finale, it is an offline event in December 2026
- only registered team members and permitted mentors can attend

Important distinction:

The national portal initially asks for the idea title, description, and prescribed PDF. It does not require us to finish every production feature before the idea submission.

However, the complete PS is the end-state judges will evaluate, so our presentation must clearly separate:

- what is working now
- what is demonstrated in the prototype
- what is the production roadmap

7. What we should not claim in the presentation

Do **not** claim that MailTrace currently has:

- an AI/ML model
- live threat-intelligence feeds
- verified attacker geolocation
- cryptographically validated SPF/DKIM/DMARC
- real-time inbox protection
- legal-grade chain of custody
- exact attacker identity
- VPN/TOR/botnet detection
- full attachment malware analysis
- Gmail ingestion
- 100% attribution confidence

The honest pitch is:

MailTrace is an explainable, local-first forensic prototype that parses suspicious email evidence, scores risk, reconstructs observed relay paths, provides reproducible infrastructure context, correlates local cases, and exports evidence-oriented reports. The next layer is live intelligence, trained NLP/ML classification, alert integration, and compliance-grade custody controls.

That is credible and still aligned with the official PS.

8. Priority order from here

P0 — Must fix before using the deck

1. Fill the real team name and portal team ID.
2. Restore/include the official section headings.
3. Remove the “with confidence” overclaim.
4. Export one final PDF from the corrected PPTX.
5. Verify it has exactly six pages and no placeholders.
6. Confirm the leader’s PEC form/submission status.

P1 — Best prototype improvements before the internal hackathon

1. Show Return-Path and Message-ID.
2. Show extracted URLs and domains as explicit IOCs.
3. Show attachment names/types if present.
4. Add a clear “observed infrastructure context” label.
5. Add a basic case search/filter view.
6. Add an explicit uncertainty field rather than implying attribution confidence.
7. Add one lightweight, honest NLP feature only if it can be tested properly.

P2 — Production roadmap, not urgent for the first PDF

1. Live GeoIP/DNS/WHOIS/MX.
2. Threat-intelligence and blacklist feeds.
3. Trained NLP/ML classifier.
4. Mail-gateway or inbox integration.
5. Pre-interaction alerting/quarantine.
6. Evidence archive and chain-of-custody log.
7. Retention and masking controls.
8. Full campaign/entity graph.

Final verdict

MailTrace is not a failed project. The core demo is working and visually presentable.

But previously, we were treating a **prototype slice** as if it already satisfied the **entire official platform scope**. The biggest things left are:

- submission metadata
- template compliance
- honest wording
- internal-selection preparation
- a few high-value forensic UI fields

The full AI, live-intelligence, alerting, and compliance stack should be presented as the next implementation phase—not falsely claimed as already complete.